BỘ GIÁO DỤC VÀ ĐÀO TẠO

TRƯỜNG ĐẠI HỌC SÀI GÒN

KHOA TOÁN - ỨNG DỤNG

BÁO CÁO ĐỒ ÁN CUỐI KỲ

Học phần: Xử lý dữ liệu lớn (Big Data)

CHỦ ĐỀ: XÂY DỰNG HỆ THỐNG SOC PHÂN TÍCH DỮ LIỆU LỚN VỚI KAFKA VÀ SPARK

Giảng viên hướng dẫn: Vũ Ngọc Thanh Sang

Sinh viên thực hiện : Nguyễn Trương Cao Sơn

Lớp : DDU1231

TP Hồ Chí Minh, năm 2024

Mục lục

LỜI MỞ ĐẦU **1**

1 TỔNG QUAN VỀ ĐỀ TÀI **2**
1.1 Giới thiệu về đề tài 2
1.1.1 Bối cảnh nghiên cứu 2
1.1.2 Lý do chọn đề tài 2
1.2 Mục tiêu và phạm vi nghiên cứu 2
1.2.1 Mục tiêu nghiên cứu 2
1.2.2 Phạm vi giới hạn của đồ án 3
1.3 Ý nghĩa thực tiễn 3
1.4 Các khái niệm và thuật ngữ cơ bản 4

2 CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ **5**
2.1 Khái quát về Xử lý dữ liệu lớn (Big Data) 5
2.1.1 Đặc trưng của dữ liệu lớn (Mô hình 3V/5V) 5
2.1.2 Xử lý theo lô (Batch) và Xử lý luồng (Stream Processing) 5
2.2 Nền tảng phân phối thông điệp Apache Kafka 5
2.2.1 Kiến trúc tổng quan của Kafka 5
2.2.2 Cơ chế lưu trữ và hoạt động (Topic, Partition) 6
2.3 Khung tính toán phân tán Apache Spark 6
2.3.1 Giới thiệu về Apache Spark và xử lý In-Memory 6
2.3.2 Mô hình Spark Structured Streaming 6
2.4 Ứng dụng trong An toàn thông tin (Hệ thống SIEM) 6
2.4.1 Khái niệm về hệ thống SIEM 6
2.4.2 Kỹ thuật tấn công Brute Force và cơ chế phát hiện 6

3 ỨNG DỤNG VÀ TRIỂN KHAI BÀI TOÁN THỰC TẾ **8**
3.1 Phương pháp nghiên cứu và kiến trúc hệ thống 8
3.1.1 Sơ đồ khối kiến trúc tổng thể 8
3.1.2 Lựa chọn công nghệ triển khai (Docker Containerization) 8
3.2 Thu thập và giả lập dữ liệu (Data Ingestion) 8
3.2.1 Xây dựng kịch bản mạng Botnet tấn công 8
3.2.2 Cấu hình Kafka Producer 8
3.3 Xử lý và phân tích dữ liệu (Data Processing) 8
3.3.1 Xử lý luồng dữ liệu với Spark Structured Streaming 8
3.3.2 Thuật toán phát hiện bất thường và trích xuất Blacklist 8

4 KẾT QUẢ THỰC NGHIỆM VÀ ĐÁNH GIÁ **9**
4.1 Kết quả chạy thực nghiệm 9
4.1.1 Giao diện sinh dữ liệu log 9

4.1.2 Bảng cảnh báo thời gian thực và File kết quả 9
4.2 Đưa ra nhận xét và đánh giá 9
4.2.1 Ưu điểm của hệ thống 9
4.2.2 Hạn chế và hướng phát triển 9

KẾT LUẬN **10**

LỜI CẢM ƠN **11**

TÀI LIỆU THAM KHẢO **12**

Danh sách hình vẽ

LỜI MỞ ĐẦU

(Viết lời mở đầu của bạn vào đây...)

Chương 1

TỔNG QUAN VỀ ĐỀ TÀI

1.1 Giới thiệu về đề tài

1.1.1 Bối cảnh nghiên cứu

Trong kỷ nguyên số hóa hiện nay, các ứng dụng web và nền tảng thương mại điện tử đang phát triển bùng nổ, kéo theo lượng dữ liệu giao dịch và lưu lượng truy cập khổng lồ được sinh ra mỗi ngày. Sự phát triển này cũng biến các hệ thống trực tuyến trở thành mục tiêu béo bở cho tội phạm mạng. Các hình thức tấn công diễn ra ngày càng tinh vi, điển hình như dò quét lỗ hổng, thu thập dữ liệu trái phép, hay phổ biến nhất là tấn công dò đoán mật khẩu thông qua các mạng lưới máy tính ma hay còn gọi là Botnet.

Trước đây, quản trị viên an toàn thông tin thường sử dụng các công cụ phân tích nhật ký hệ thống truyền thống hoặc xử lý dữ liệu theo từng đợt. Tuy nhiên, khi đối mặt với lượng dữ liệu lớn lên tới hàng chục nghìn yêu cầu mỗi giây, các hệ thống cũ nhanh chóng bộc lộ điểm yếu: quá tải, nghẽn cổ chai và độ trễ cao. Việc phát hiện một cuộc tấn công sau vài giờ, hay thậm chí vài phút, là quá muộn để ngăn chặn rủi ro rò rỉ dữ liệu hoặc sập hệ thống.

Thực tiễn đó đặt ra yêu cầu cấp thiết phải xây dựng một Trung tâm Điều hành An ninh thế hệ mới, gọi tắt là hệ thống SOC. Hệ thống này phải có khả năng tiếp nhận và phân tích dữ liệu nhật ký hệ thống theo thời gian thực để chặn đứng các mối đe dọa ngay khi chúng vừa khởi phát.

1.1.2 Các khái niệm và công nghệ nền tảng

Để làm rõ hướng giải quyết cho bài toán nêu trên, phần này sẽ giải thích bản chất của các khái niệm và công nghệ cốt lõi được sử dụng xuyên suốt đồ án:

- **Nhật ký hệ thống (Log):** Là các tệp dữ liệu tự động ghi lại mọi hoạt động xảy ra trên máy chủ (ai vừa truy cập, địa chỉ IP là gì, hành động thành công hay thất bại). Đây chính là nguồn "nguyên liệu"đầu vào để hệ thống tiến hành phân tích.

- **Mạng máy tính ma (Botnet) và Tấn công dò đoán mật khẩu (Brute Force):** Kẻ tấn công thường khống chế hàng ngàn máy tính của người dùng bình thường tạo thành một mạng lưới (Botnet). Chúng điều khiển mạng lưới này cùng lúc gửi hàng triệu lượt thử mật khẩu sai (Brute Force) nhằm làm sập hệ thống hoặc đánh cắp tài khoản.

- **Apache Kafka (Trạm trung chuyển dữ liệu):** Về bản chất, Kafka là một hệ thống điều phối và truyền tải dữ liệu tốc độ cao. Khi website bị tấn công, dữ liệu nhật ký sinh ra ồ ạt như một cơn lũ. Nếu đổ trực tiếp lượng dữ liệu này vào hệ thống phân tích, máy chủ chắc chắn sẽ quá tải. Kafka ra đời để đóng vai trò như một "hồ chứa nước đệm". Nó hứng chịu toàn bộ lưu lượng khổng lồ từ máy chủ web, lưu trữ tạm thời một cách an toàn, rồi điều tiết dòng chảy đó sang cho các bộ phận xử lý phía sau với tốc độ phù hợp, giúp toàn bộ kiến trúc không bao giờ bị nghẽn.

- **Apache Spark (Khung tính toán trực tiếp trên bộ nhớ):** Nếu Kafka là người vận chuyển, thì Spark chính là "bộ não"xử lý. Đặc điểm làm nên sức mạnh của Spark là khả năng tính toán trực tiếp trên bộ nhớ RAM thay vì phải ghi và đọc dữ liệu liên tục từ ổ cứng như các công nghệ cũ. Nhờ vậy, Spark có thể hút dữ liệu liên tục từ Kafka, thực hiện đếm số lượt truy cập, gom nhóm các địa chỉ IP và phát hiện ra các điểm bất thường gần như ngay lập tức.

1.1.3 Lý do chọn đề tài

Từ những khái niệm trên, có thể thấy việc ứng dụng các công nghệ xử lý dữ liệu lớn vào bài toán an toàn thông tin là một hướng đi thiết thực và đầy tiềm năng. Sự kết hợp hoàn hảo giữa khả năng chịu tải tuyệt vời của Kafka và tốc độ xử lý tức thời của Spark chính là lời giải trọn vẹn cho bài toán độ trễ trong giám sát hệ thống.

Hơn nữa, một luồng dữ liệu nhật ký không chỉ có giá trị về mặt phát hiện mã độc mà còn chứa đựng vô vàn thông tin hữu ích về hành vi người dùng, phục vụ cho công tác phân tích và thống kê của doanh nghiệp. Do đó, đề tài **"Xây dựng hệ thống SOC phân tích dữ liệu lớn với Kafka và Spark"** được lựa chọn nhằm kết hợp kiến thức chuyên ngành vào một bài toán thực tế, mang lại góc nhìn đa chiều: vừa bảo vệ hệ thống nền tảng, vừa tận dụng triệt để nguồn dữ liệu sẵn có.

1.2 Mục tiêu và phạm vi nghiên cứu

1.2.1 Mục tiêu nghiên cứu

Đồ án được thực hiện với các mục tiêu cụ thể sau:

- **Về mặt lý thuyết:** Nghiên cứu và hiểu rõ kiến trúc, nguyên lý hoạt động của hệ sinh thái dữ liệu lớn hiện đại, đặc biệt là luồng xử lý thời gian thực thông qua Kafka và Spark.
- **Về mặt thực hành:** Tự xây dựng và triển khai thành công một luồng dữ liệu thông suốt từ khâu thu thập, xử lý trực tiếp đến khâu trực quan hóa lên bảng điều khiển.
- **Về mặt ứng dụng:** Xây dựng thuật toán phát hiện bất thường dựa trên ngưỡng thống kê để tự động nhận diện các địa chỉ IP có hành vi tấn công và đưa vào danh sách chặn.

1.2.2 Phạm vi giới hạn của đồ án

Do giới hạn về thời gian và tài nguyên phần cứng, đồ án tập trung vào các phạm vi sau:

- **Dữ liệu đầu vào:** Sử dụng dữ liệu nhật ký máy chủ web được giả lập liên tục theo thời gian thực, bao gồm cả lưu lượng người dùng bình thường và các kịch bản tấn công.
- **Mô hình triển khai:** Toàn bộ hệ thống Kafka và Spark được triển khai cục bộ thông qua nền tảng ảo hóa Docker để đảm bảo tính đồng nhất và dễ dàng đóng gói.
- **Phương pháp phân tích:** Đồ án sử dụng phương pháp thống kê và phân tích tập luật cơ bản để phát hiện tấn công thay vì áp dụng các mô hình học máy phức tạp.

- **Trực quan hóa:** Giao diện giám sát được phát triển bằng ngôn ngữ Python kết hợp với các thư viện hỗ trợ vẽ biểu đồ động.

1.3 Ý nghĩa thực tiễn

Đồ án cung cấp một mô hình thu nhỏ nhưng bao hàm đầy đủ các thành phần cốt lõi của một nền tảng dữ liệu lớn thực tế. Kết quả của đồ án mang lại những giá trị rõ nét trên ba phương diện:

- **Về mặt vận hành an ninh:** Hệ thống chứng minh khả năng thay thế các công cụ rà soát lỗi thủ công vốn có độ trễ cao. Nhờ phân tích dữ liệu trực tiếp trên bộ nhớ, hệ thống giúp đội ngũ bảo mật tự động nhận diện và trích xuất danh sách các địa chỉ IP độc hại gần như tức thời. Đây là tiền đề quan trọng để tích hợp với hệ thống tường lửa, giúp tự động chặn đứng tin tặc từ sớm.

- **Về mặt tận dụng dữ liệu thống kê:** Đồ án khẳng định sự đa dụng của nền tảng phân tích luồng. Cùng một nguồn dữ liệu đầu vào, ngoài việc phát hiện mã độc, hệ thống có thể đồng thời trích xuất các thông tin về lưu lượng truy cập hay tỷ lệ lỗi máy chủ. Quản trị viên có thể theo dõi sức khỏe website liên tục mà không gây thêm áp lực xử lý cho cơ sở dữ liệu chính yếu của doanh nghiệp.

- **Về mặt kiến trúc công nghệ:** Việc sử dụng trạm trung chuyển Kafka giúp tách biệt hoàn toàn cụm máy chủ web (nơi sinh dữ liệu) và cụm phân tích phía sau. Nhờ thiết kế phân tán này, hệ thống có khả năng mở rộng linh hoạt và chịu lỗi cực tốt, duy trì sự hoạt động nhịp nhàng ngay cả khi đối mặt với lượng truy cập tăng đột biến.

Chương 2

CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ

2.1 Khái quát về Xử lý dữ liệu lớn (Big Data)

2.1.1 Đặc trưng của dữ liệu lớn (Mô hình 3V/5V)

Dữ liệu lớn (Big Data) không chỉ đơn thuần là sự gia tăng về mặt dung lượng lưu trữ, mà còn bao hàm sự phức tạp trong việc thu thập và xử lý. Mô hình truyền thống mô tả Big Data qua 3 đặc trưng cốt lõi:

- **Volume (Dung lượng):** Lượng dữ liệu khổng lồ sinh ra liên tục. Đối với hệ thống SOC, đây là hàng triệu dòng log truy cập web mỗi ngày.
- **Velocity (Tốc độ):** Yêu cầu phải được xử lý tức thời (Real-time) để phát hiện tấn công.
- **Variety (Đa dạng):** Dữ liệu đến từ nhiều nguồn và định dạng khác nhau (JSON, XML, Text).

Ngày nay, mô hình này mở rộng thành 5V với **Veracity (Tính xác thực)** - đảm bảo độ tin cậy của dữ liệu log để tránh nhận diện sai (False Positive), và **Value (Giá trị)** - khả năng trích xuất thông tin hữu ích (như IP tấn công hoặc phễu chuyển đổi hành vi).

2.1.2 Xử lý theo lô (Batch) và Xử lý luồng (Stream Processing)

Trong xử lý dữ liệu truyền thống, dữ liệu thường được lưu trữ tĩnh trong các cơ sở dữ liệu và được truy vấn định kỳ (Batch Processing). Cách này phù hợp để làm báo cáo tổng kết nhưng hoàn toàn bất lực trước các cuộc tấn công mạng đang diễn ra.

Ngược lại, đối với các hệ thống hiện đại như giám sát an ninh mạng, dữ liệu log máy chủ được sinh ra liên tục dưới dạng một luồng bất tận. Lúc này, phương pháp xử lý luồng (Stream Processing) trở nên thiết yếu. Nó cho phép hệ thống tính toán các phép phân tích thống kê ngay tại thời điểm bản ghi dữ liệu vừa được sinh ra. Điều này giúp giảm thiểu độ trễ (latency) từ hàng giờ xuống chỉ còn vài mili-giây, đáp ứng yêu cầu phản ứng nhanh trước các sự cố.

2.2 Nền tảng phân phối thông điệp Apache Kafka

2.2.1 Kiến trúc tổng quan của Kafka

Apache Kafka là một nền tảng truyền phát sự kiện phân tán (Distributed Event Streaming Platform) mã nguồn mở. Kiến trúc của Kafka giải quyết triệt để bài toán nút thắt cổ chai (bottleneck) trong truyền tải dữ liệu giữa nhiều hệ thống.

Nó hoạt động theo mô hình Publish-Subscribe và đóng vai trò như một bộ đệm (Buffer) khổng lồ: nơi các chương trình sinh dữ liệu (Producers) đẩy thông điệp vào, và các chương trình xử lý (Consumers) kéo dữ liệu ra. Việc tách biệt (decouple) hoàn toàn này giúp hệ thống xử lý phía sau (như Spark) không bị quá tải hay sập nguồn khi lượng người truy cập website tăng đột biến (Spike traffic).

2.2.2 Cơ chế lưu trữ và hoạt động (Topic, Partition)

Luồng dữ liệu trong Kafka được tổ chức theo các **Topic** (Chủ đề). Để đảm bảo khả năng mở rộng, mỗi Topic được chia nhỏ thành các **Partition** (Phân vùng). Dữ liệu ghi vào Partition mang tính tuần tự và bất biến, cho phép các Consumer đọc dữ liệu một cách độc lập và song song với tốc độ cực cao.

2.3 Khung tính toán phân tán Apache Spark

2.3.1 Giới thiệu về Apache Spark và xử lý In-Memory

Apache Spark là một hệ thống tính toán phân tán song song hoạt động trên bộ nhớ RAM (In-Memory Computing). Khác với các công cụ thế hệ cũ như Hadoop MapReduce thường phải ghi dữ liệu trung gian xuống ổ cứng gây chậm trễ, Spark thực hiện phần lớn các tác vụ trên RAM, đem lại tốc độ xử lý vượt trội, cực kỳ phù hợp cho bài toán theo thời gian thực.

2.3.2 Mô hình Spark Structured Streaming

Trong đồ án này, công nghệ Spark Structured Streaming được áp dụng làm "bộ não"xử lý. Kỹ thuật này coi luồng dữ liệu thời gian thực như một bảng quan hệ vô hạn (Unbounded Table) đang liên tục được bổ sung dòng mới.

Bằng cơ chế chia lô cực nhỏ (Micro-batching), hệ thống có thể áp dụng các truy vấn SQL chuẩn (như Gom nhóm *groupBy*, Đếm *count*) lên luồng dữ liệu một cách dễ dàng. Đồng thời, cơ chế này cũng đảm bảo tính nhất quán và khả năng chịu lỗi (Fault-tolerance) nhờ việc lưu lại các checkpoint trong quá trình chạy.

2.4 Ứng dụng trong An toàn thông tin (Hệ thống SIEM)

2.4.1 Khái niệm về hệ thống SIEM

SIEM (Security Information and Event Management) là giải pháp quản lý sự kiện và thông tin bảo mật. Nhiệm vụ cốt lõi của SIEM là thu thập log từ nhiều nguồn (máy chủ, tường lửa, ứng dụng), sau đó tương quan và phân tích dữ liệu để phát hiện các dấu hiệu bất thường, cung cấp cái nhìn toàn cảnh về bức tranh an ninh của doanh nghiệp.

2.4.2 Kỹ thuật tấn công Brute Force và cơ chế phát hiện

Tấn công Brute Force (dò đoán mật khẩu) là một trong những phương thức xâm nhập phổ biến nhất. Kẻ tấn công thường sử dụng một mạng lưới các máy tính bị nhiễm mã

độc (Botnet) để tự động gửi hàng ngàn yêu cầu đăng nhập với các tổ hợp tài khoản/mật khẩu khác nhau.

Đặc điểm nhận dạng của loại tấn công này là tần suất xuất hiện dày đặc của các mã trạng thái HTTP lỗi (ví dụ: 401 Unauthorized) từ cùng một địa chỉ IP. Trong phạm vi đồ án, công nghệ Big Data được ứng dụng để liên tục giám sát trạng thái này. Bằng cách đếm số lượng phản hồi 401 của mỗi IP, nếu con số này vượt qua một ngưỡng (Threshold) được định trước trong một cửa sổ thời gian (Time Window), hệ thống sẽ tự động ghi nhận đó là hành vi độc hại và xuất IP đó ra danh sách chặn (Blacklist).

Chương 3

ỨNG DỤNG VÀ TRIỂN KHAI BÀI TOÁN THỰC TẾ

3.1 Phương pháp nghiên cứu và kiến trúc hệ thống

3.1.1 Sơ đồ khối kiến trúc tổng thể

(Nội dung...)

3.1.2 Lựa chọn công nghệ triển khai (Docker Containerization)

(Nội dung...)

3.2 Thu thập và giả lập dữ liệu (Data Ingestion)

3.2.1 Xây dựng kịch bản mạng Botnet tấn công

(Nội dung...)

3.2.2 Cấu hình Kafka Producer

(Nội dung...)

3.3 Xử lý và phân tích dữ liệu (Data Processing)

3.3.1 Xử lý luồng dữ liệu với Spark Structured Streaming

(Nội dung...)

3.3.2 Thuật toán phát hiện bất thường và trích xuất Blacklist

(Nội dung...)

Chương 4

KẾT QUẢ THỰC NGHIỆM VÀ ĐÁNH GIÁ

4.1 Kết quả chạy thực nghiệm

4.1.1 Giao diện sinh dữ liệu log

(Nội dung...)

4.1.2 Bảng cảnh báo thời gian thực và File kết quả

(Nội dung...)

4.2 Đưa ra nhận xét và đánh giá

4.2.1 Ưu điểm của hệ thống

(Nội dung...)

4.2.2 Hạn chế và hướng phát triển

(Nội dung...)

KẾT LUẬN

(Nội dung kết luận...)

LỜI CẢM ƠN

(Nội dung lời cảm ơn...)

TÀI LIỆU THAM KHẢO

(Liệt kê tài liệu...)